بسم الله الرحمن الرحیم

Data and Network Security

SESSION 02

Secure Design Principles and the Trusted Computing Base



Solmaz Salimi
Sharif University of Technology

s.salimi@sharif.edu

Last lecture and today's lecture

Session 1	Security requirements, attacker capabilities, and trust assumptions
Part 1	TCB, economy of mechanism, and least privilege
Part 2	Complete mediation, reference monitors, and failure policy
Part 3	Defense in depth, usable interfaces, and audit records
Part 4	Open design, shared mechanisms, and security economics
Part 5	Revocation and the time-of-check/time-of-use problem

Running example: a research data export service

ASSET

Dataset A is restricted to approved Project A researchers.



REQUESTERS

Alice has approval for A. Bob has a valid account and can submit jobs, but has no grant for A.

POLICY

An export reads A on behalf of a requester with an applicable grant.

Execution

A worker executes queued exports. Its service identity is distinct from the requesting researcher.

Part 1: The trusted computing base



The trusted computing base (TCB)

Trusted

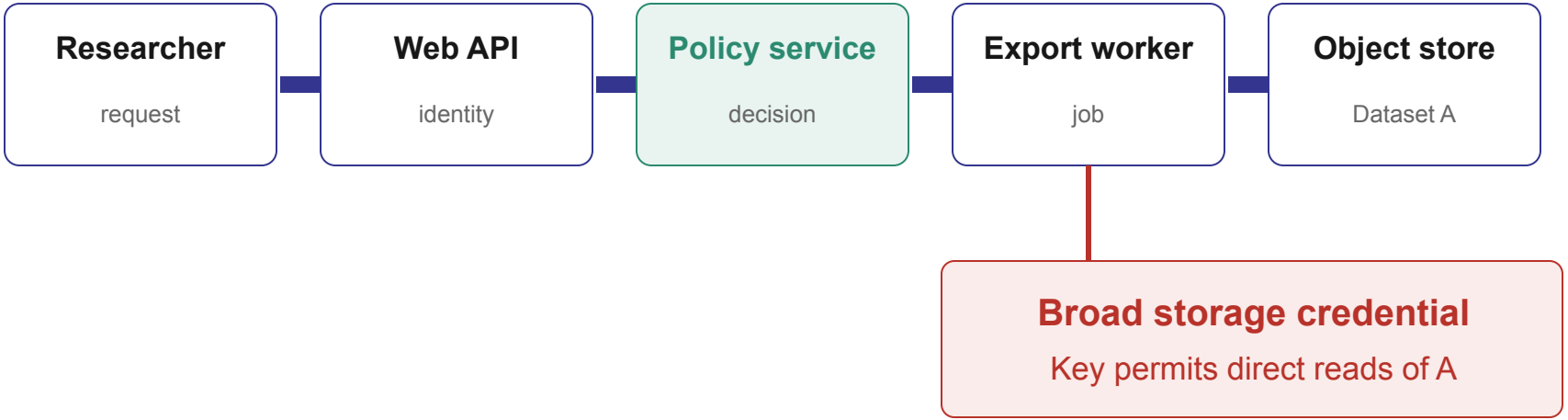
relied on for a security property

The trusted computing base is the set of hardware, software, and protection mechanisms whose correct operation the chosen security property relies on.



- **CPU and isolation**
- **Kernel and runtime**
- **Authorization code**
- Keys and verification
- Protected policy state
- Privileged services
- Storage access gate

Worker authority determines a security dependency



A worker with a standing read key can obtain A independently of the requester's grant. Its use of that key is therefore part of the enforcement argument.

Identify the TCB for a particular property

Property	The storage gate permits only reads carrying applicable authority.
Enforcement	Token issuer, verifier, gate, protected policy state, and their isolation dependencies.
Outside	The browser’s presentation code does not enforce the storage access rule.
Data release	A worker that receives plaintext remains trusted for any requirement governing its later output.

Economy of mechanism favors a small, simple enforcement design that can be analyzed.

Least privilege constraints delegated operations

Broad standing key

- Reads every dataset
- Lists every project
- Writes export archives
- Long-lived credential

Authority spans projects



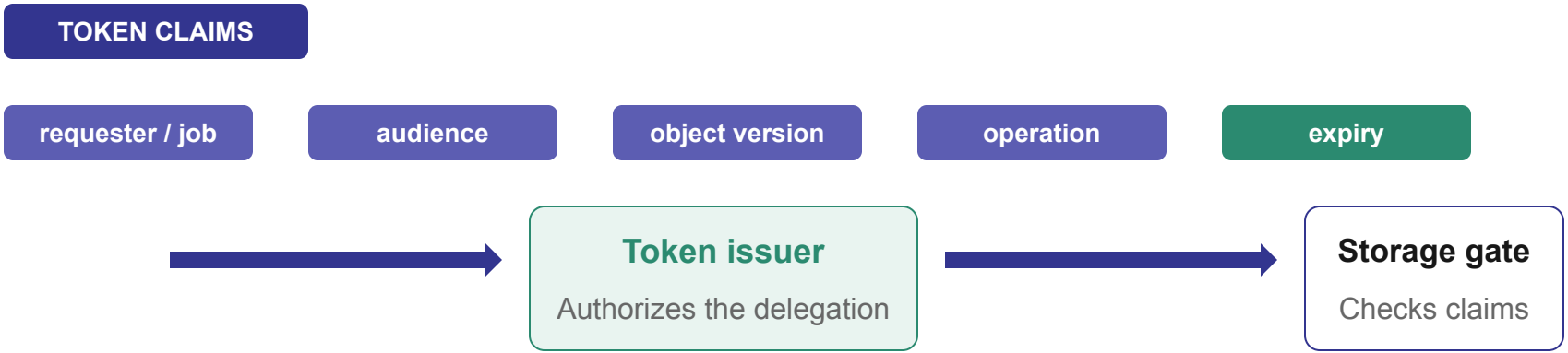
Scoped export token

- Bound to requester and job
- One object and operation
- Short validity period
- Issued after approval

Bearer possession grants its scope

Delegate the minimum objects, operations, and duration needed to complete the task.

The storage gate enforces the delegated scope



Decision

The requested object and operation must fall within the token's authority.

Mechanism

The issuer authenticates the requester; the gate verifies the issued token and the applicable current state.

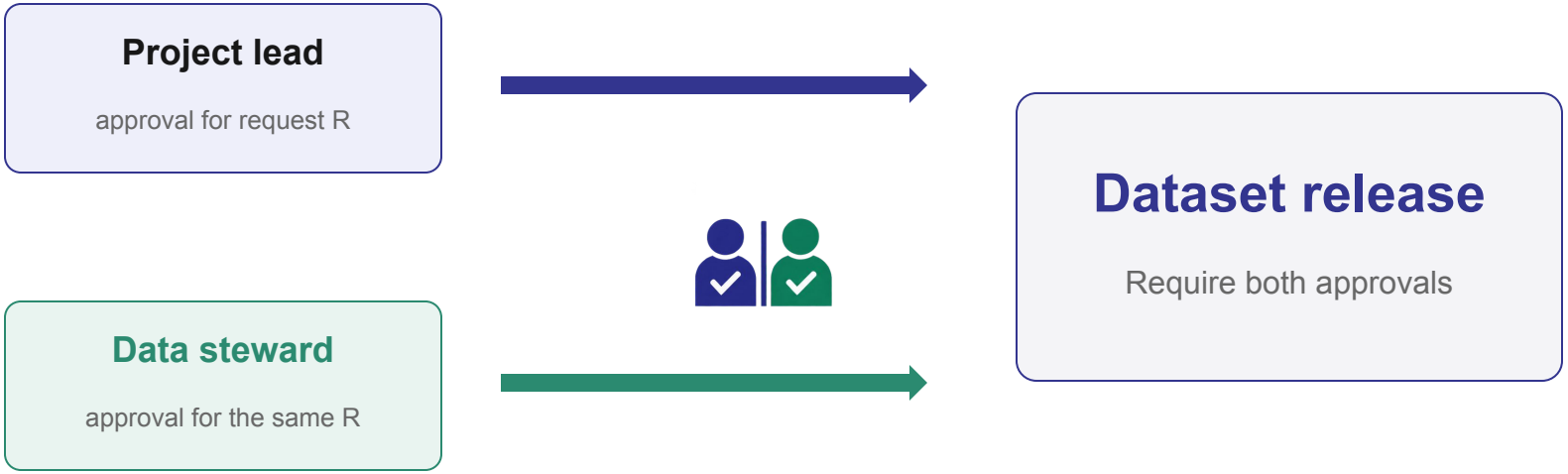
Validation of an export token

Authenticity	Verify the MAC or signature with an accepted issuer key.
Audience	Require the intended storage gate as the token audience.
Scope	**Match the object version and operation to the delegated rights.**
Delegation	Check the covered requester and job context against the request.
Freshness	Check expiry and the revocation state required by policy.
Replay	Record consumption if the policy requires one use.

A subject claim identifies the delegation. It does not, by itself, authenticate the presenter of a bearer token.



Separation of privilege requires independent conditions



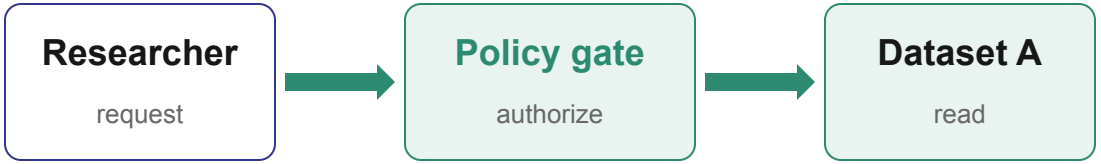
Bind both approvals to the same release request and distinct authorized identities. A shared account would collapse the separation.

Part 2: Complete mediation and fail-safe defaults



Complete mediation across export and maintenance paths

Portal path



Maintenance path



Complete mediation

Maintenance access must enforce its own explicit grant policy at an equivalent storage gate.

A correct portal check covers only requests that actually pass through it.

Reference monitor requirements



1

Always invoked

Every protected access invokes the monitor.

2

Tamper resistant

Enforcement code and policy state are protected against unauthorized changes.

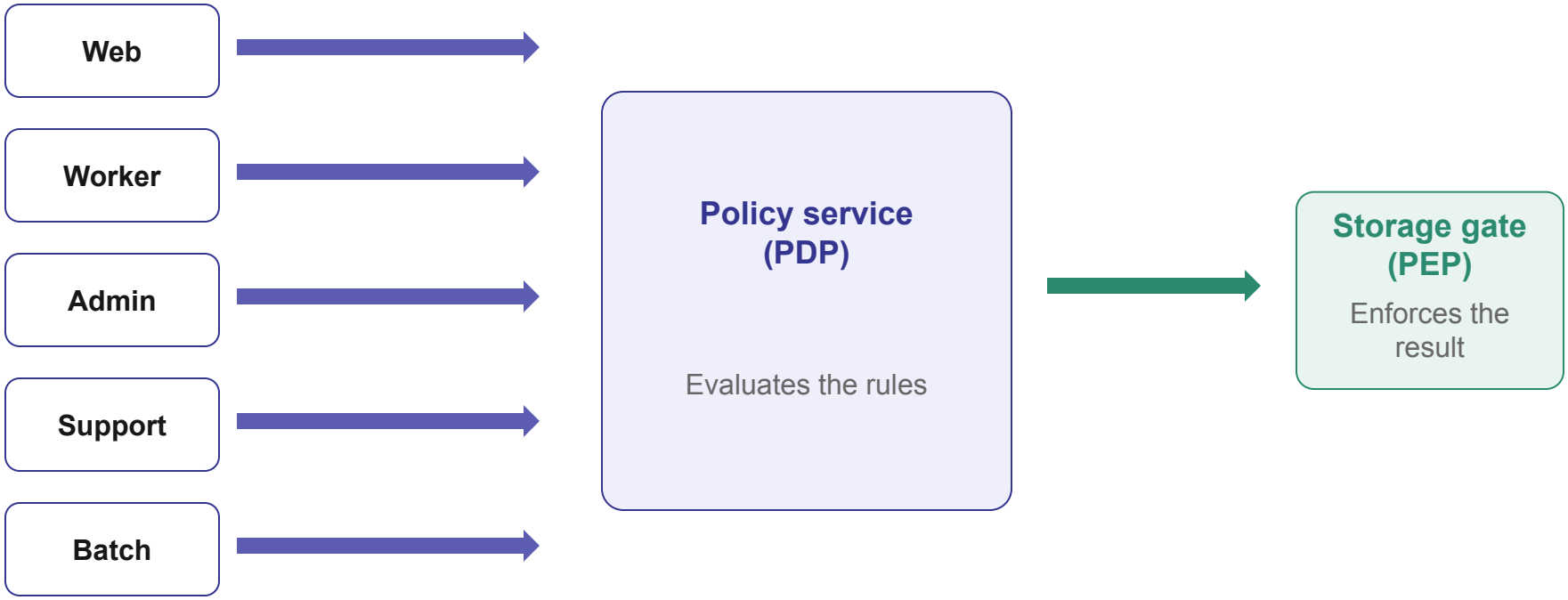
3

Verifiable

The mechanism is small and structured enough for correctness analysis.

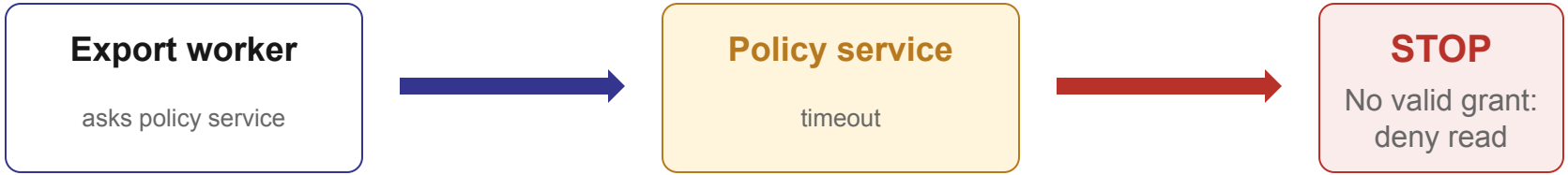
These three requirements connect complete mediation, isolation, and economy of mechanism.

Policy decision and policy enforcement



A policy decision point (PDP) evaluates rules. A policy enforcement point (PEP) applies the result to the operation it mediates.

Fail-safe defaults require an applicable grant



This service requires a current authorization decision. A timeout leaves the request without the grant needed to read A.

A cached grant is usable only when its validity is explicitly defined by the policy.

Failure behavior follows the service policy

Failure	Policy response	Availability consequence
Applicable grant is absent	**Deny the read**	Request project approval
Required audit record unavailable	**Wait before release**	Export queue grows
Token cannot be verified	**Deny the read**	Export waits for recovery
Destination not approved	**Wait before release**	Researcher waits for review

For this service, a durable decision record and an approved destination are preconditions for releasing an export.

Part 3: Defense in depth and usable enforcement



Defense in depth uses controls with distinct functions

Application authorization	Checks the requester before queuing the export
Scoped storage token	Constrains the worker’s object and operation
Network boundary	Restricts the sources of storage requests
Audit alert	Records unexpected activity for investigation

Independence matters: one administrator controlling every layer creates a shared failure mode.



Psychological acceptability in an access interface

Weak denial

Access denied

No reason
No recovery path



Actionable denial

Your export grant has expired

Request renewed project approval

Exceptional access follows a separate approval procedure with a reason, expiry, and recorded decision.

For Alice’s known export request, the interface explains the failed precondition and the next authorized step.

Audit records reconstruct an authorization decision

A RECORD SHOULD IDENTIFY

- requester / job
- object version
- action
- **decision**
- policy version
- route / worker

Authorization

decides whether the read may happen

Logging

Records link requester, job, object, and policy version so the decision can be reconstructed.

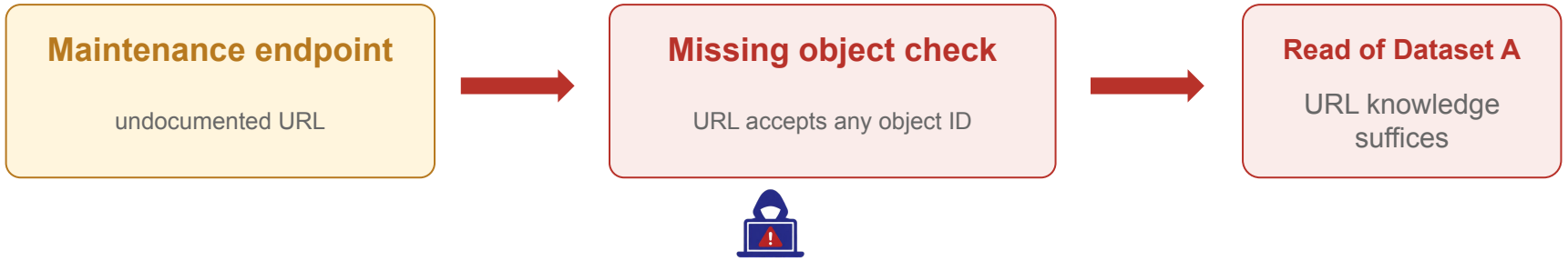


Protect record integrity and restrict log access; the log may itself contain sensitive metadata.

Part 4: Open design and shared mechanisms



Open design distinguishes mechanisms from secrets



The endpoint must enforce access even when its URL and implementation are known.

- **Keys and credentials remain secret. Algorithms and access-control mechanisms can be public.**
- **Authenticate the user and authorize each object operation.**

Least common mechanism and the cost of a control

Shared authority

- One storage identity for many projects
- Shared mutable policy state
- Cross-project dependency

Separate authority

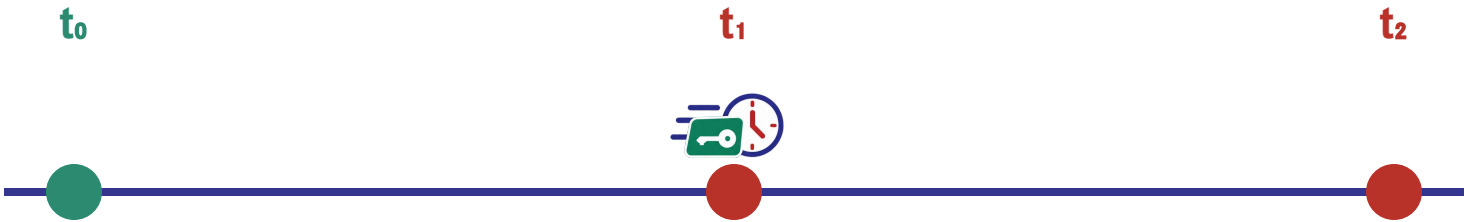
- Project-specific identities and grants
- Narrow administrative interfaces
- Additional operational work

Minimize security-sensitive shared mechanisms. Evaluate the resulting isolation together with engineering and operating costs.

Part 5: Authorization changes over time



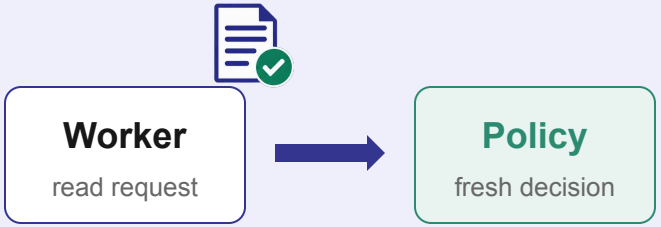
A queued export uses a decision made earlier



The chosen policy denies a first read that occurs after revocation commits.

TOCTTOU: couple the check to the protected use

Fresh check at use



The grant can change after a separate check.

Bound check and use



A running stream needs its own revocation rule.

Serialize the authorization decision and read admission with grant updates. Token expiry and revocation are different events.

References

CS 161	Security principles and the trusted computing base. Berkeley course textbook, Chapter 1.
Design principles	Saltzer and Schroeder, The Protection of Information in Computer Systems, Proceedings of the IEEE, 1975.
Reference monitor	NIST glossary and SP 800-53 terminology. Always invoked, tamper resistant, and verifiable.

Next: access control models and data protection

An enforcement mechanism needs a precise policy

DAC	MAC	RBAC	Information flow
Owners grant rights to objects	Mandatory labels constrain access	Roles organize permissions	Labels constrain where data can go

Session 3 specifies the policy represented by grants, labels, roles, and information-flow rules.